



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

CyberSecurity

2 - “Overview: Main Concepts and Terminology” *[Chapter 1]*

Gabriele D'Angelo <g.dangelo@unibo.it>

<https://www.unibo.it/sitoweb/g.dangelo/en>

Outline



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Computer Security **Concepts**
- **Threats, Attacks, and Assets**
- Fundamental Security **Design Principles**
- **Attack Surfaces** and **Attack Trees**
- Computer Security **Strategy**

Fundamental Questions



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



Defining a Threat Model

The focus is on three **fundamental questions**:

- **what assets** do we need to **protect**?
- **how** are those assets **threatened**?
- **what** can we do to **counter those threats**?

Threat Model



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



Informal Definition of Threat Model: Who is my enemy? What do we have to protect? What are the potential consequences of an attack of my system?

In cybersecurity, a **threat model** is a **structured way of identifying potential threats, vulnerabilities, and risks** to a system, application, or organization. It is a **systematic approach to understanding the possible attack vectors, threat actors, and the potential impact of successful attacks.** (definition provided by “claude.ai”, 04/03/2024)

Computer Security (NIST definition)



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



This computer security definition says that it is impossible to have security if we are not able to guarantee the security baseline: CIA Triad (for some system is enough, for others we need to extend the security properties)

«The protection ~~afforded to~~ an automated information system ~~in order~~ ^{al fine}
^{garantita a}

^{di conseguire gli obiettivi previsti in materia di salvaguardia}
~~to attain the applicable objectives of preserving the~~ **integrity**,

availability and **confidentiality** of information system resources.»

- It includes hardware, software, firmware, information/data, and

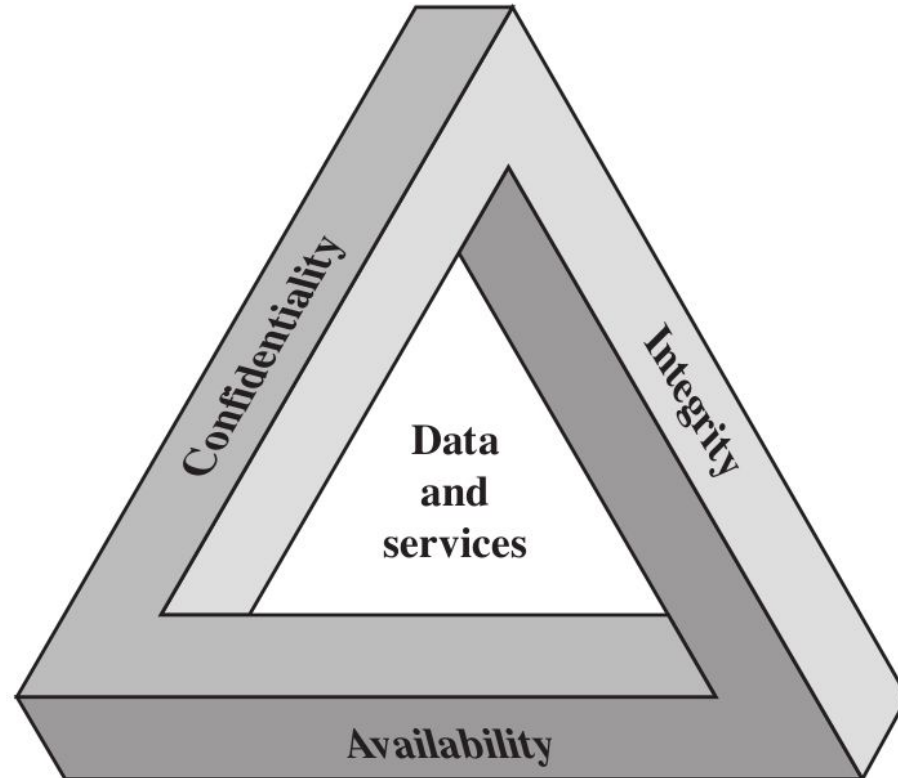
telecommunications

Prof Approach: Awareness, Problem Definition (every system is different: to define the problem, i need to define the security properties that i need to guarantee) and Solutions

The Security Requirements “CIA” Triad



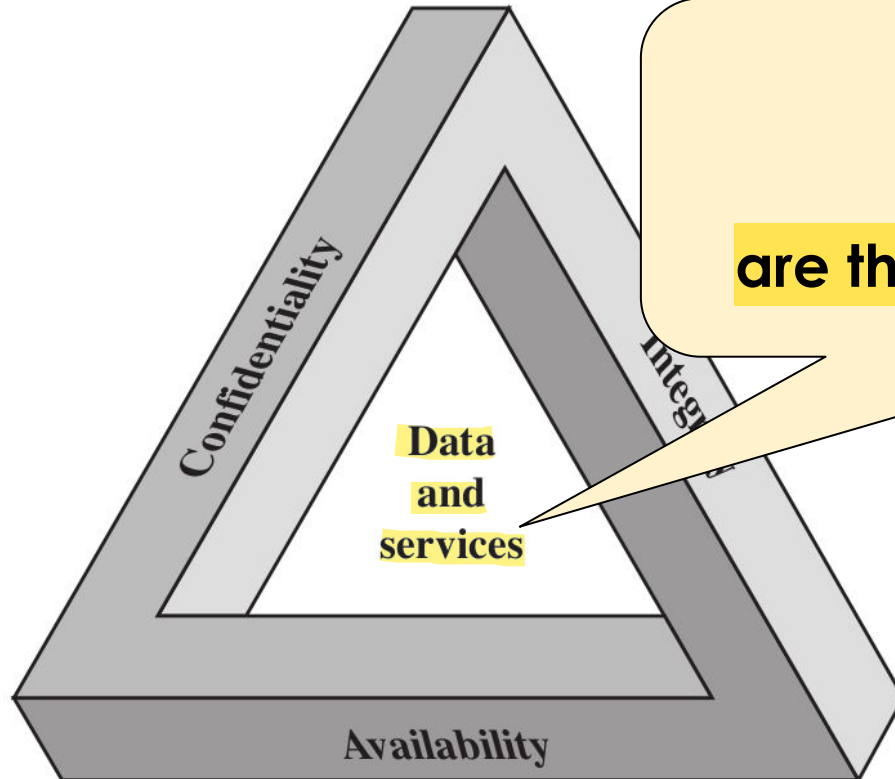
ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



In this approach

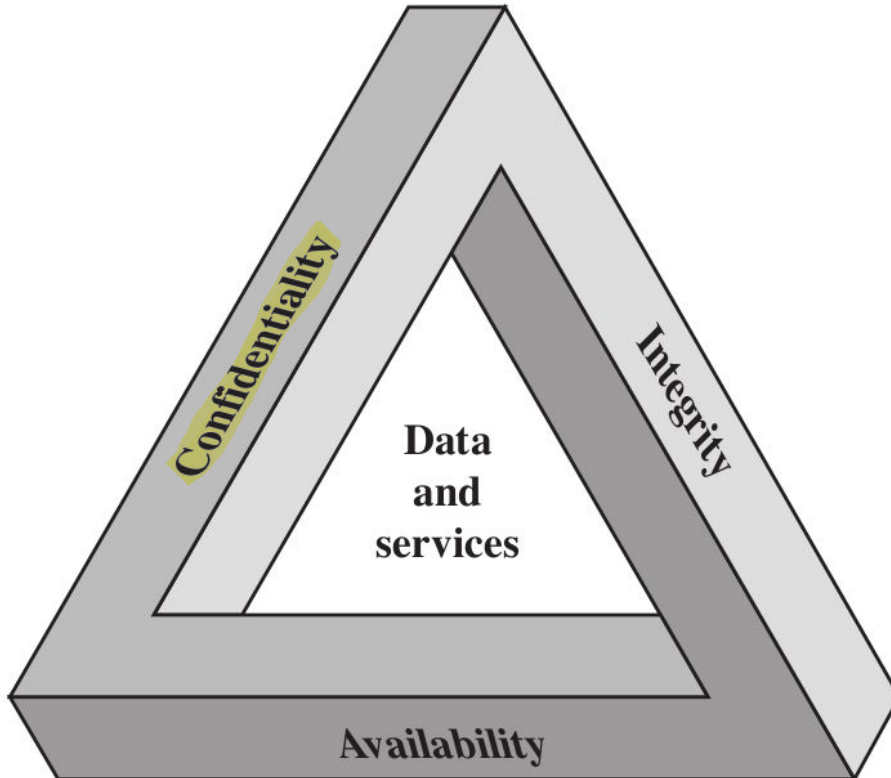
“data and services”

are the core elements to protect

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality divided in two different things:

- **data confidentiality**
- **privacy** (small subset of Cybersecurity)

1) Data Confidentiality: The "How"

Confidentiality is a technical obligation. Once an organization has your data, they have a duty to ensure that only authorized people can see it. If a hacker breaks into a server and steals a list of passwords, that is a loss of confidentiality, regardless of whether the data was "private" or not.

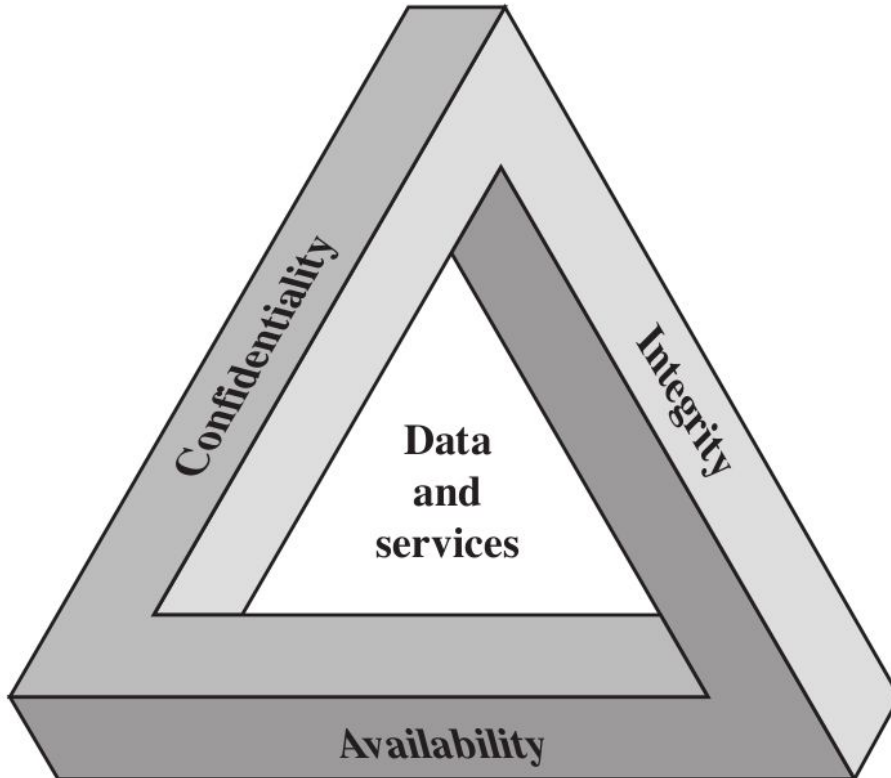
2) Privacy: The "What and Why"

Privacy is a policy and legal concept. It's about the choice of the individual. For example, if you choose to post your phone number on a public social media profile, you have waived your privacy for that data. However, the social media company still has a duty of confidentiality to ensure a random person can't log into your account and change that number. The Golden Rule: You can have confidentiality without privacy (e.g., a company keeps your secret data safe but sells it to advertisers anyway), but you cannot have privacy without confidentiality (if the data leaks, your privacy is gone).

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality

- data confidentiality
- privacy

example: logs of my activity on Unibo WiFi must be private

data confidentiality

private or **confidential**

information is not made

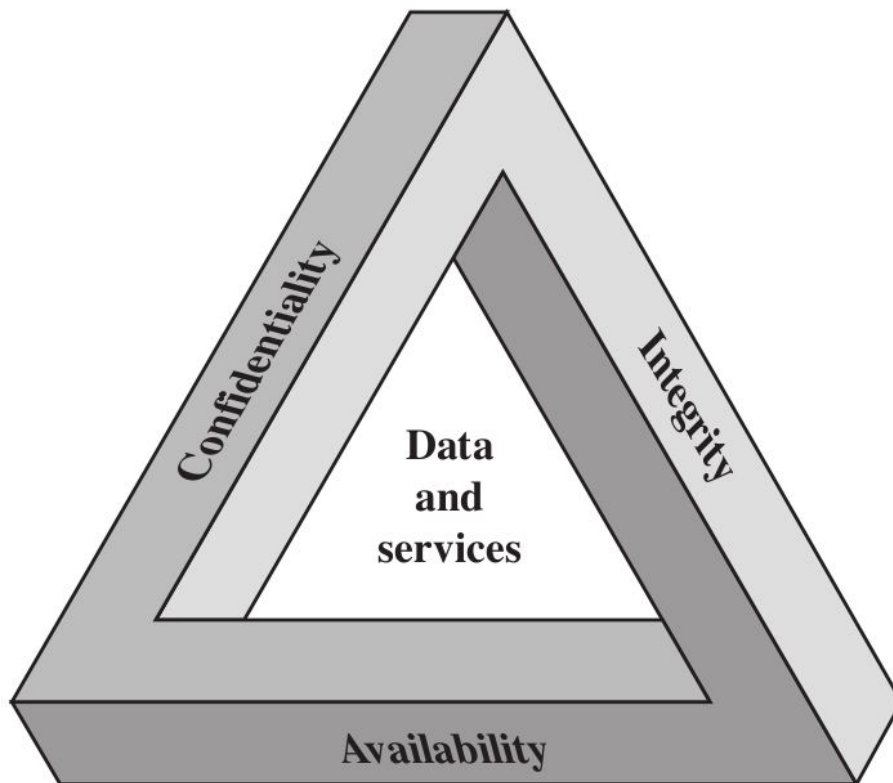
available or ^{divulgate} disclosed

to unauthorized individuals

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality

- data confidentiality
- privacy

example: I can
control the level of
visibility of my
pictures on Instagram

privacy

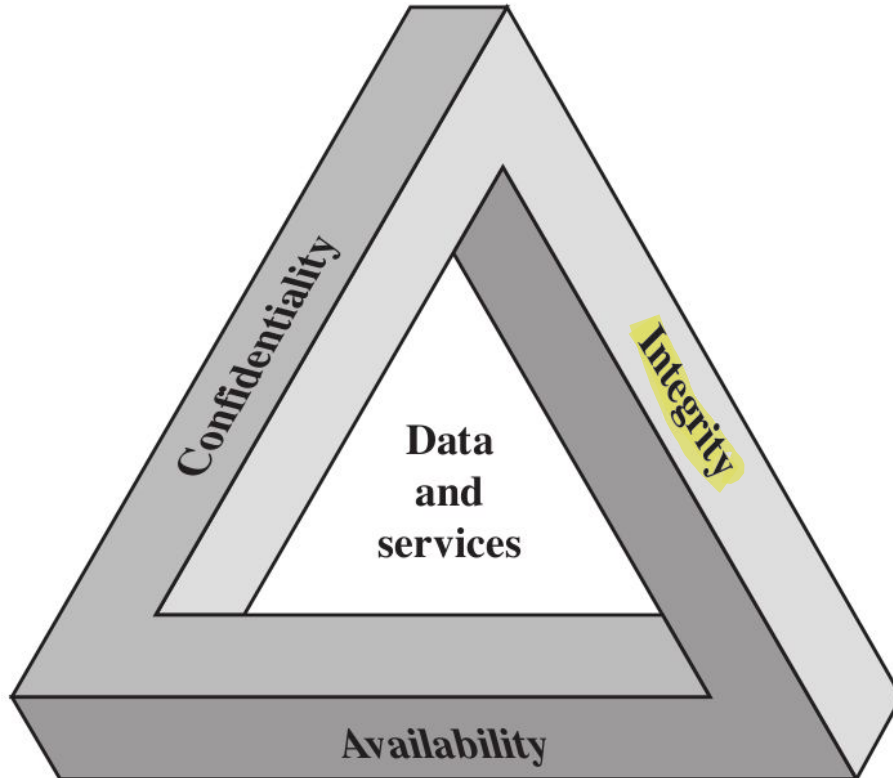
For some data can
be done, for other is
difficult to be done
or not be done

**individuals control what
information related to them
may be collected and stored,
by whom and to whom this
information may be disclosed**

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality

- data confidentiality
- privacy

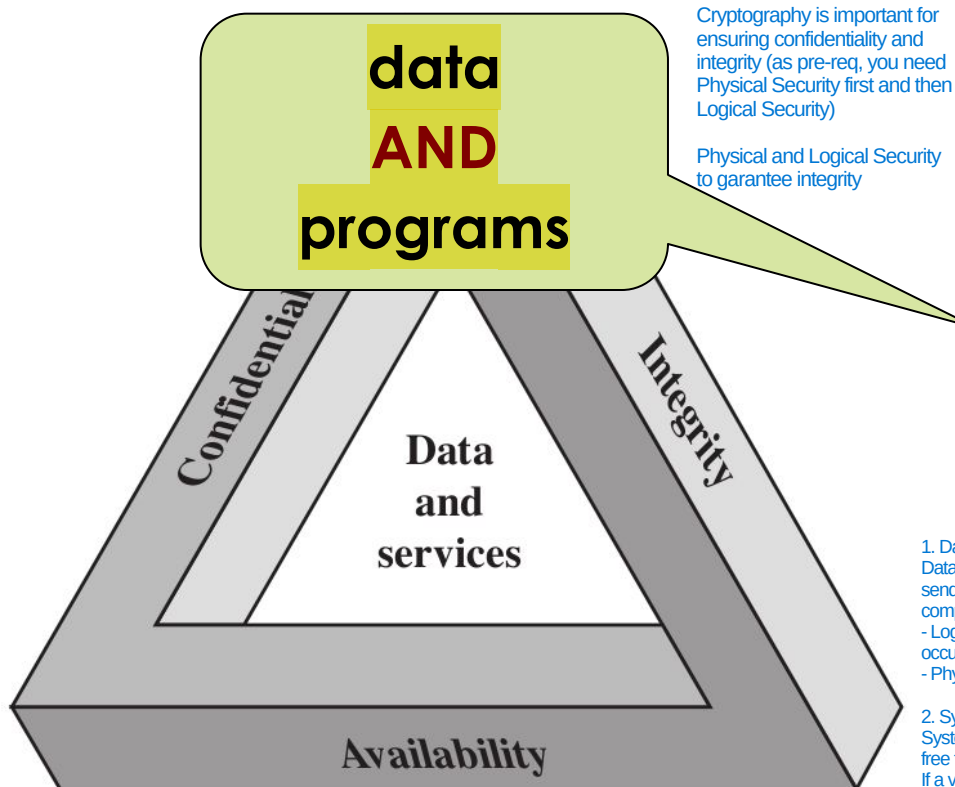
integrity

- data integrity
- system integrity

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality

- data confidentiality
- privacy

integrity

No unauth modification are done

- data integrity
- system integrity

1. Data Integrity: Is the information correct?

Data integrity ensures that information remains exactly as it was intended to be throughout its entire lifecycle. If you send a wire transfer for \$100 and a hacker changes the value to \$1,000 mid-transit, the data integrity has been compromised.

- Logical Integrity: Ensuring the data makes sense within a database (e.g., you can't have a "shipping date" that occurs before the "order date").

- Physical Integrity: Ensuring the data isn't corrupted by hardware failures or power outages.

2. System Integrity: Is the machine behaving?

System integrity means the system is "unimpaired." It is performing its scheduled tasks according to its specifications, free from unauthorized manipulation of its internal processes.

If a virus replaces a legitimate Windows system file with a malicious one, the system integrity is gone. Even if your personal files (data) haven't been touched yet, the environment they live in is no longer trustworthy.

The Security Requirements “CIA” Triad

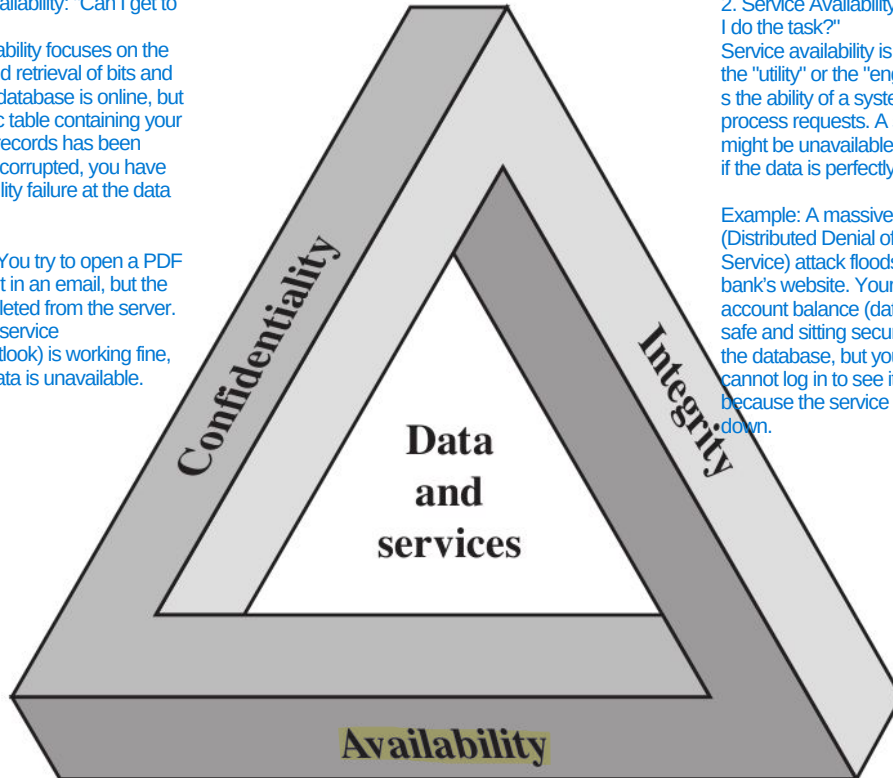


ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

1. Data Availability: "Can I get to my stuff?"

Data availability focuses on the storage and retrieval of bits and bytes. If a database is online, but the specific table containing your customer records has been deleted or corrupted, you have an availability failure at the data level.

Example: You try to open a PDF attachment in an email, but the file was deleted from the server. The email service (Gmail/Outlook) is working fine, but your data is unavailable.



2. Service Availability: "Can I do the task?"

Service availability is about the "utility" or the "engine." It's the ability of a system to process requests. A service might be unavailable even if the data is perfectly safe.

Example: A massive DDoS (Distributed Denial of Service) attack floods a bank's website. Your account balance (data) is safe and sitting securely in the database, but you cannot log in to see it because the service is down.

confidentiality

- data confidentiality
- privacy

integrity

- data integrity
- system integrity

availability

If there isn't, there is no security: if not available, customer cannot visualize its data

- data availability
- services availability

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Confidentiality

Integrity

Availability

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Confidentiality

Integrity

Availability

- Preserving authorized restrictions on **information access** and **disclosure**
- Including means for protecting personal **privacy** and proprietary information

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Confidentiality

Integrity

Availability

- Guarding against improper **information modification** or **destruction** (example: ransomware to attack the integrity of a system)
- **Comprende la garanzia** Including ensuring information (Non-repudiation is the legal and technical assurance that a particular person cannot deny having performed a specific action.) **non-repudiation** and **authenticity** (Authenticity is the guarantee that a message, transaction, or data bit actually comes from the source it claims to be from.)

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Confidentiality

Integrity

Availability

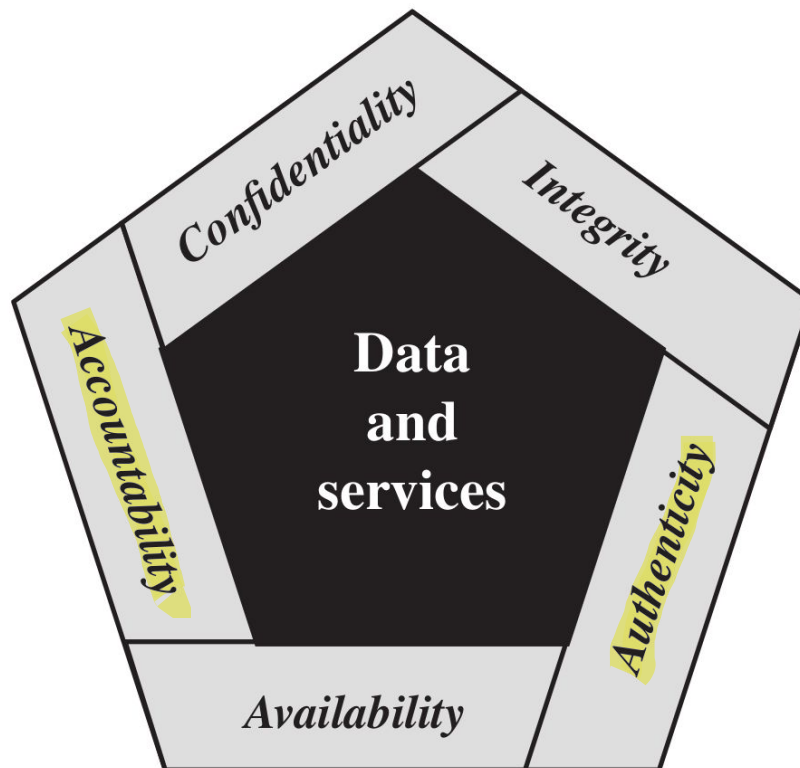
Garantire un accesso tempestivo
ed affidabile ai dati (e ai servizi)

Ensuring **timely** and
reliable access to and
use of **data** (and
services)

The Security Requirements



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



Sometimes, the Triad is not enough. We need a Pentagon

Every single system has different requirements: in some cases Triad is enough, in other cases the Triad isn't enough and the Pentagon is enough, in other cases Pentagon isn't enough and we need something else.

Complexity of the system is higher in Pentagon Requirements, than in Triad

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Authenticity

1. Being Genuine (The "What")

This means the item or person is the real deal, not a replica, a fake, or an imposter.

- Data: A software update actually came from Apple, not a hacker.
- Person: The person logging into your bank account is actually you, not someone who found your password.

2. Being Able to be Verified (The "How")

A claim of being genuine is useless if you can't prove it. Verification requires a unique marker that is difficult to forge.

- In the physical world: A watermark on a passport or a handwritten signature.
- In the digital world: A Digital Signature or a Security Certificate (SSL/TLS).

3. Being Trusted (The "Result")

Once the verification succeeds, "Trust" is established. This allows the system to grant access or allow a transaction to proceed. If verification fails, the connection is untrusted and blocked.

Accountability

1. "Actions of an Entity"

An "entity" isn't always a person. It can be a user, a system process, or an automated bot. Accountability means every click, file deletion, or login attempt is captured.

2. "Traced Uniquely"

This is the most critical part. If three people share the password "Admin123", you have zero accountability. If a file is deleted, you know "an admin" did it, but you can't trace it uniquely to Bob, Sarah, or Mike. To have accountability, every entity must have a unique identity (UID).

3. "To That Entity"

This provides "Non-repudiation." It means the evidence is so strong that the entity cannot deny their involvement.

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Authenticity

- Property of being **genuine** and being able to be **verified** and **trusted**
- For example: confidence in the validity of a transmission, a message, or a message originator

Accountability

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Authenticity

Being able to guarantee the Accountability is incredibly hard, but it depends on your setup (company, internet, etc..)

Accountability

Accountability is a Trade-off with Privacy: Accountability often conflicts with privacy, creating a trade-off where increasing transparency for oversight reduces individual anonymity

Accountability is possible in organization or companies, but you have less privacy. It is difficult to have Accountability on the Internet due to anonymity, decentralization, and legal challenges

- The requirement for **actions of an entity** to be **traced uniquely to that entity**
- For example: ability to find the originator of a transmission, a message, or an action

Key Security Concepts

It is the process of using the gathered evidence (the audit logs and digital fingerprints) to hold a person or organization responsible in a court of law: Criminal Prosecution (This is when a government charges an individual with a crime), Civil Litigation (This is when one private party sues another) and Regulatory Action (This is when a government agency punishes a company for failing to follow security standards.)



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Authenticity

Without Accountability is not possible to trace in which part of the system the fault has originated

While technical controls (like firewalls) physically stop an attack, deterrence aims to persuade a potential attacker that the effort isn't worth the risk.

Accountability

The requirement for **actions of an entity** to be **traced uniquely to that entity**

For example: *ability to find the originator of a **transmission**, a **message**, or an action*

I need Accountability

Necessary to support

non-repudiation, deterrence,

fault isolation, intrusion

detection and prevention...

recovery and legal action

I monitor the system, I check what happens. If something that is anomalous is happening on the system, I stop immediately what happens

Important to have in case of Failure of system protection (System compromised in real world, it happens). We can do Intrusion Detection and Prevention if we have Accountability

If things go wrong, you need to be able to decide what has been compromised and what not, and restore the things that has been compromised and maintain everything that has not been compromised

This classification is Qualitative, not quantitative enough
(we need a Quantitative Classification of Level of Impact)

Level of Impact

For being able to properly evaluate what is the Minimization of the risk, I need to be able to properly measure the Level of Impact (I can't only use this Qualitative Classification: I need a Quant one)



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

A compromise of a system or an attack on a system, can have a different level of impact

Low

The loss could be expected to have a **limited adverse effect** on organizational **operations**, organizational **assets**, or **individuals**

Moderate

The loss could be expected to have a **serious adverse effect** on organizational **operations**, organizational **assets**, or **individuals**

High

The loss could be expected to have a **severe or catastrophic adverse effect** on organizational **operations**, organizational **assets**, or **individuals**

Computer Security Challenges



The use of multiple cryptographic algorithms, security protocols, and tools in a single system creates significant challenges for security, interoperability, and performance. While combining techniques can sometimes strengthen security, it often results in increased complexity, potential vulnerabilities at interface points, and increased maintenance overhead.

- Computer security is **not as simple as it might first appear to the novice**

(for every single possible potential attack, you will need to be able to evaluate what is the probability of this specific attack and for each, you will need to be able to decide what is the level of impact of the specific attack that will be after that implemented)

- Potential attacks on the ^{system} security features must be considered

(Example: internet)

- Procedures used to provide particular services are **often counterintuitive**

Procedures used to provide security in legacy systems are frequently counterintuitive because they require retrofitting protections onto technology designed before modern threats existed. As systems grow over time, understanding how different parts provide specific features makes securing them difficult, often leading to the need for "compensating controls" rather than fundamental fixes.

- **Physical and logical placement** needs to be determined

if you don't know where the computation is executed, you have no idea of the integrity of the system

- **Multiple algorithms or protocols** may be involved

as it defines the perimeter, restricts lateral movement, and dictates the effectiveness of both tangible and digital controls. As physical and cyber domains merge, a unified strategy (addressing where a machine is located and where it resides on a network) is essential to mitigate risks like unauthorized access, device theft, and tampering.

Computer Security Challenges

when you want to
protect your system



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Attackers** only need to find a **single weakness** vulnerability in the system
- **Developers/administrators** need to find **all weaknesses**
- It is an **asymmetric game!** *(i.e. the players do not stand on equal ground)* the knowledge of the system is important,
so do not disclosure so much information
- The attacker can **combine multiple weaknesses** (in the real world, start with non-tech
vulnerability, humanware, then chain
of tech vulnerability)

Computer Security Challenges



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Users** and **system managers** tend to **not see the benefits** of security **until a failure occurs**
 - **good security** is **invisible** (linked to usability: if the security is invisible, it doesn't impact the work of the users)
 - **bad security** is **visible only after a security incident**
 - (usually) **good security does not generate revenues** (*i.e. if compared with advertisements, marketing etc.*)

Computer Security Challenges



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Security requires **regular and constant monitoring** (*i.e. security is a process and not a product*) ... **security is costly!** Every single day, you will have to invest money and maintaining a proper security level
- It's often an **afterthought** to be incorporated into a system **after the design is complete** (*i.e. the Internet*) (Every time you have a system and you need to introduce security after the system design is completed, you have a big problem because it is impossible to have a proper level of security of something that has been already designed)
(Example: Two-level Authentication, too much time to login in an account than using only password, but you have more security) use protocol, to enhance security, on top of internet low protocols
- **Thought of as an impediment to efficient and user-friendly operation...**

(again) **security is a cost!**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

The attacker reduce the costs for the attack in all way possibles, so the first phase of the attack is often automated (after the initial phases, the person is triggered)

or attacker

Adversary (threat agent): an **entity that attacks**, or is a **threat** to, a

system

(It isn't only about an attack that is implemented, it can be also about potential attack). We need to anticipate what will happen: so we will need to consider all the entities (example: person, algos, etc..) that can be interested in attacking our system.

The attacker is who is willing to violate the security policy. So, if you missed part that are important in the security policy, the violation of the security policy, very likely, cannot be flagged as an incident because it isn't considered in your security policy.

- **Attack**: an assault on system security that derives from an **intelligent**

(Example: Evade the Auth Mechanism)

threat; a deliberate attempt **to evade security services** and **violate**

the **security policy** of a system

a document or a bunch of different documents in which you define what is the level of security that you expect, what can be done inside your organisation and what cannot be done inside your organisation

(Example: can you play on Uni PCs during launch? It is defined in the security policy of the system)

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Adversary (threat agent)**: an entity that poses a **threat** to, a system
- **Attack**: an assault on system security that derives from an **intelligent threat**; a deliberate attempt **to evade security services** and **violate** the **security policy of a system**





In some cases the threat is not much “intelligent”

Example: some (not all) Denial of Service attacks
are rather simple (or stupid)

Example: Volumetric DoS: throw a lot of packets to the system to attack

or is a **threat** to, a

- **Attack**: an assault on system security that derives from an **intelligent threat**; a deliberate attempt **to evade security services** and **violate** the **security policy of a system**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

In general, a Countermeasure is whatever can be done for being able to eliminating, preventing or minimizing the harm that it can caused

Countermeasure: an **action, device, procedure, or technique** that

reduces a threat, a vulnerability, or an attack by **eliminating** or

preventing it, by **minimizing** the **harm it can cause**, or by discovering

and reporting **it** so that **corrective actions can be taken**

the vulnerability

Very often, in CySec, it is not possible to eliminate the problem because we have constraints that make impossible to totally eliminate the problem. So, we prevent or minimize the Attack surface

Discover and Report the Vulnerability is a countermeasure (Discover and selling it to Vulnerability Broker isn't a countermeasure)

What happens if the attacker is able to exploit part of my Attack surface to compromise a specific service that is open to the external of my organisation? How much time for come back operational? This must be done every day for every risk that involves my organisation (this must be done for proper evaluating the assets that are inside my system)



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Computer Security Terminology

- System: HW and SW used to provide some stuff/services of the business (can be a bunch of interconnected systems).
- Organisation: something related to Management of company and pays you money

- **Risk:** an **expectation of loss** expressed as the **probability** that a **particular threat** will exploit a **particular vulnerability** with a **particular harmful result**

When we are in charge of the CySec of the System, our job is minimizing the risk by means of whatever you want (i.e specific measures)

So, you can reduce impact and likelihood with tech and human solutions (example: filtering to reduce likelihood of download malware and education to reduce impact)

RISK MATRIX

In some cases, very likely, you are going to use a combination of different mitigation technics.

Impact	Likelihood				
	Rare	Unlikely	Possible	Likely	Almost certain
Catastrophic	moderate	moderate	high	critical	critical
Major	low	moderate	moderate	high	critical
Moderate	low	moderate	moderate	moderate	high
Minor	very low	low	moderate	moderate	moderate
Insignificant	very low	very low	low	low	moderate

For every single threat to your system, you must be able to properly classify this threat assigning a specific level of risk (cell of the risk matrix). Example: phishing email to download from outside the organisation a ransomware (likelihood almost certain, impact it encrypt all data and backups and the attacker asks money, you are with a critical risk). Based on the risk, you have to find a countermeasure to reduce the impact, so it reduces the risk (example: education of the employee, in this case)

This table is the follow-up of the Classification of Level of Impact

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

It is Important both for tech purposes because i can defend only something that is indicated in the security policy, otherwise it is impossible for me to defend different parts of the organisation, but currently the Security policy is shaped by a lot of stuff that is, for example, not technical or it is imposed from outside (example: requirements of certifications)



Security policy: a **set of rules and practices** that specify **how a system**

or organization provides security services ^{with the aim} *(to protect sensitive and*

critical system resources)

Are you able to enforce the Security Policy? If you aren't able to enforce the Security policy with your boss, you have a problem, that typically happens. Enforcing the Security policy, will make you really unpopular inside the organisation (you will have tech and not tech problems (dealing with people))

Example: the **password policy** (i.e. **strong passwords and their**

expiration) of an organization is part of its **security policy**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **System resource (asset): data;** a **service** provided by a system; a **system capability**; an **item** of **system equipment**; a **facility** that houses system operations and equipment
building (where the computation is placed)
- **Threat:** a **potential** for violation of security, which exists when there is a circumstance, capability, action, or event that could **breach security** and **cause harm**
(it is important to define level of impact and risk involved with these potential threats)

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

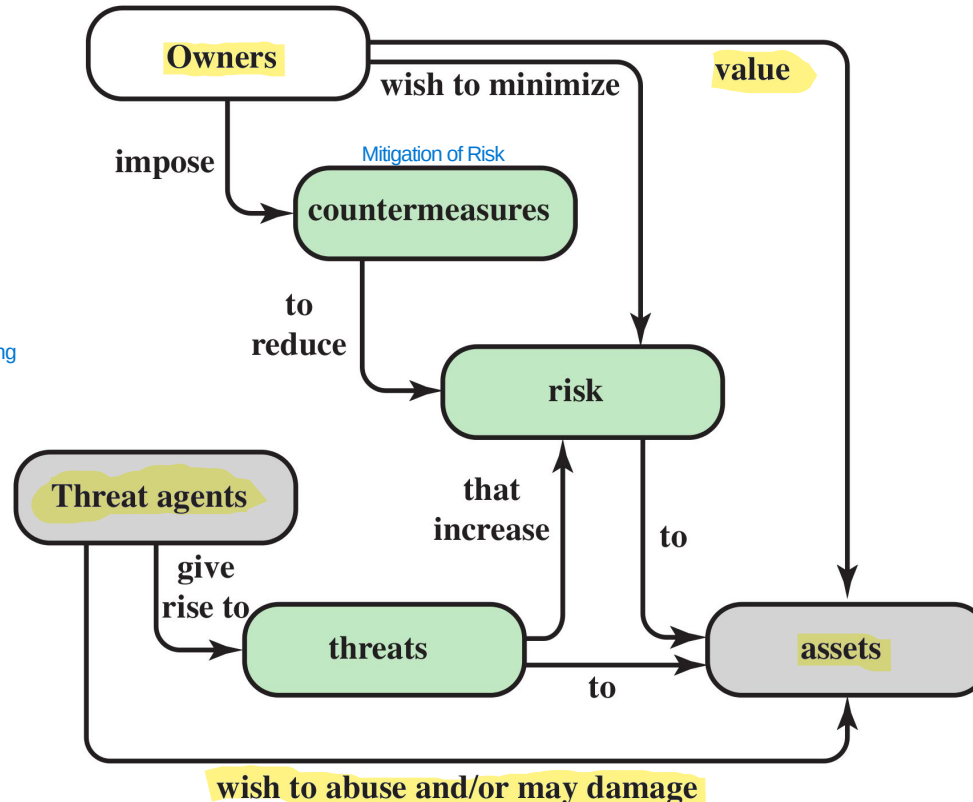
- **Vulnerability**: a **flaw** or **weakness** in a system's **design, implementation,**
or **operation** and **management** that could be **exploited** to **violate the**
system's security policy
(if it isn't in the Security policy, it isn't a vulnerability (outside of the scope of the system):
in some cases, it is an error/flaw in the policy or in the system implemented)

Example: *there is a vulnerability in the **software** or the **users** are **not properly educated** to deal with email phishing*

Security Concepts and Relationship



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



It seems easy to manage the risk of all assets (Asset Risk Management), but in practice to list all the threats and then being able to decide the proper countermeasures can be costly and boring

Warning: The diagram provides a “business-level” overview (who owns what and who wants to cause harm), but it lacks the “technical” details (how the harm occurs) and other parts.

In the middle between Business and Threat Agent, there are Assets (core of the business for providing services)

Vulnerabilities, Threats and Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Vulnerability** (of system resources):

Terminology (specific to Vulnerability)

system is **corrupted** (loss of integrity)

when there is a

This occurs when a system resource is modified in an unauthorized or unintended manner. Integrity ensures that data is “correct,” complete, and unaltered. Example: A hacker breaks into a bank’s db and doesn’t steal money, but changes your account balance from €100 to €1,000,000. The system is “corrupted.”

system is **leaky** (loss of confidentiality)

when there is a

This occurs when sensitive information is accessed or stolen by someone who is not authorized to do so. This is known as a “data breach.” Example: A vulnerability in a website allows an unauthorized person to access patients’ medical records. The data has not been lost or altered, but it has been “leaked.”

system is **unavailable** or very slow / **unresponsive** (loss of availability)

when there is a

This occurs when authorized users cannot access a resource when they need it. Example: A DDoS attack that floods a server with fake requests until it crashes. Or, ransomware that encrypts your files: the data is still there (its integrity and confidentiality may be intact), but you cannot use it.

Vulnerabilities, Threats and Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Threats:**

Formalization of Threat

- capable of **exploiting vulnerabilities**
- represent a **potential security harm**

Vulnerabilities, Threats and Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

(three categories)



Attacks (threats carried out):

is no more potential: is something that is happening

What matters is not the classification itself, but the consequences of the classification:

- active: i can monitor what happens and react and try to mitigate (example: attacker trying to stole an account trying different passwords, the system can, one solution, block the account avoiding login)
- passive: monitoring isn't useful, so i need to work on countermeasure (very hard to implement) (example: attacker sniff the connection and grab the wifi password encrypted without interacting with system)

○ **active** - attempt to **alter/affect** the **system resources** (direct interaction with system)

○ **passive** – does **not** (directly) **affect** the **system resources** (no direct interaction with the system itself: like intercept communication)

○ **insider** or **outsider** (is it from an **internal** or **external** thread?)



In the past, everything that is outside is bad and everything that is inside is good (example: LAN protocol is designed based on this). Now, the world changed a lot and most of attacks comes from inside, for example by compromission of device/applications. Now, it is used a lot the Zero-Trust Approach (everything is untrusted up to when you demonstrate that you are legitimated to do something: every time that there is an interaction with the infrastructure, you must be able to validate yourself and to demonstrate that you are legitimated)

More info about **active** and **passive** attacks in the following...

- **Attacks** (threats)
 - **active** - attempt to **alter/affect** the **system resources**
 - **passive** – does **not** (directly) **affect** the **system resources**
 - **insider** or **outsider** (is it from an **internal** or **external thread**?)

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

All three are very important

- **Any means** taken **to deal with a security attack**

try my best to
☐ **prevent** the attack

☐ **detect** the attack until it is too late

the system is compromised, so i need to
☐ **recover** from attack

Define the steps for each, before being compromised

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Any means** taken to deal with a security attack

- prevent

- detect

- recover

Is that always possible?

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Any means** taken to deal with a security attack

- prevent

(Example: Vulnerability in the Web Server and i don't have the update to fix it. So, because i can't shutdown the entire Web Server and i can't do nothing to prevent the compromission, i do my best for enhancing the detection of compromission if it happens)

- detect

- recover

No! That's why detection and
recovery are of main importance

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Any means** taken to deal with a security attack
 - prevent
 - detect
 - recover

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Countermeasures

-  May introduce new vulnerabilities
- Residual vulnerabilities may remain
- The **goal** is to minimize residual level of risk to the assets
(that is to implement some kind of **mitigation**)

Typically, you have similar type of attack of different systems (so classify them is important to deny the attack to this category). Although the CIA triad was originally developed to define security objectives, in practice it is frequently used to classify threats based on which pillar they target.

Threat Consequences

Threats linked to CIA Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

4 Different classification that is useful to understand the different typical attacks



Unauthorized disclosure is a threat to **confidentiality**

There are various types of attacks that lead to the same end result: someone sees something they shouldn't.

Exposure: the accidental or intentional disclosure of sensitive data in an unsecured environment.

- **exposure:** *this can be **deliberate** or be the result of a human, hardware, or software **error***

Example: An employee accidentally posts an Excel file containing salary information on the company's public website, or a database server is left unsecured on the internet.

Interception: occurs when data is captured as it travels from point A to point B (more related to communication in a network or not)

- **interception:** *unauthorized **access** to data*

Example: The classic man-in-the-middle (MitM) attack. You connect to the airport's Wi-Fi, and an attacker intercepts the data packets you send to your bank.

Inference: Secret information is obtained by analyzing data that is not secret or by observing the system's behavior.

- **inference:** *e.g., traffic **analysis** or use of limited access to get detailed information*

Example: I can't read the contents of your emails (they're encrypted), but I see that every morning at 9:00 a.m. you send an email to the legal department and then to the CEO. I can infer that there's a legal negotiation underway.

Intrusion: direct, unauthorized access to a system for the purpose of stealing data (example: get data from db).

- **intrusion:** *unauthorized **access** to sensitive data*

Example: A hacker exploits a vulnerability in the web server to gain a "shell" (control of the computer) and manually copies sensitive files to their PC.

Threat Consequences



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

3 Different classification that is useful to understand the different typical attacks

Deception is a threat to either **system** or **data integrity**

It's an attack on identity. The system thinks it's talking to "A," but it's actually talking to "B."

Example: Trojan malware impersonating good software with backdoors or other things. Another example: modify IP address to a packet to avoid filters on addresses and push malware

masquerade: e.g., Trojan horse; or an attempt by an unauthorized user to gain **access** to a system **by posing as an authorized user**

(example: DNS poisoning corrupts the records in a DNS resolver's cache, redirecting users from legitimate websites to fake or malicious sites)

This is a direct attack on the data. In this case, the attacker already has access (or gains it) and alters the existing information.

falsification: the **alteration** or **replacement** of valid data or the **introduction** of false data

Example: I enter new fake records (e.g., I create a fictitious "admin" user so I can log in later).

This is a fundamental concept for transactions and policies. It occurs when someone performs an action and then lies by claiming they didn't do it, or when the system is unable to prove that it was done.

repudiation: an entity **deceives** another by falsely **denying**

responsibility for an act

Example: I make an online purchase, receive the merchandise, but then tell the bank, "I never authorized that transaction; give me my money back."

the internet is insecure and the travel of data on the internet is less secure than in the system

Threat Consequences



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

3 Different classification that is useful to understand the different typical attacks



Disruption is a threat to **availability** or system **integrity**

The system simply stops existing or functioning because the physical or logical foundation is destroyed.

- **incapacitation:** *a result of physical **destruction** of or **damage** to system hardware* Example: A malicious actor cuts the fiber optic cables leading to a data center.

This is a "glitch" or a "poisoning" of the system. The system is still "up," but it's doing the wrong thing or behaving chaotically.

- **corruption:** *system resources or services function in an **unintended manner; unauthorized modification*** Example: A hacker modifies the routing table of a router. The router is "on," but it's sending all your traffic to a dead end or a malicious server.

The system is working correctly, and the data is fine, but the "path" to get there is blocked or so slow that it becomes useless.

- **obstruction:** *e.g. **overload** the system or interfere with communications* Example: A DDoS (Distributed Denial of Service) attack. The server is fine, the data is safe, but 1 million fake users are knocking on the door, so the "real" users can't get in.

It isn't important to classify PRECISELY every incident. When i want to know if a system is secure or not, I need a procedure to be followed: use these 4 slides as Guidelines to assess the security of the system

Threat Consequences

The main criticism of this model (last 4 pages) is that the categories often bleed into one another. This is likely why it feels "weak" to you (but it's not):

Example: A Ransomware attack.

- It starts as an Intrusion (Unauthorized Disclosure).
- It performs Falsification by encrypting your files (Deception/Integrity).
- It ends in Incapacitation because you can't use your PC (Disruption/Availability).

Because one attack can hit all four categories, it can feel like the classification isn't "sharp" enough to define a specific event.



2 Different classification that is useful to understand the different typical attacks



Usurpation is a threat to **system integrity**

This is a threat to the ownership and access of a resource.



This is the "Hostile Takeover" of a resource. An attacker gains the control of a part of the system and can now use the resource as if they were the owner.

misappropriation: *an entity assumes **unauthorized** logical or physical*

control of a system resource

Example: An attacker gains "Root" or "Administrator" access to your web server. They haven't broken it (yet), but they now "own" all the data and processing power on it.

The attacker doesn't necessarily "own" the whole system, but they force a specific part of it to do something it wasn't supposed to do, something that hurts your security.

misuse: *causes a system component to perform a function or service*

*that is **detrimental to system security***

Example: Using a legitimate company email server to send out millions of Spam messages or Phishing links. The server is doing what it was built for (sending emails), but it is being misused in a way that damages the company's reputation and security.

Another Example: An attacker installs a Crypto-miner on your server. The server still hosts your website, but it's wasting 90% of its CPU power making money for the hacker.

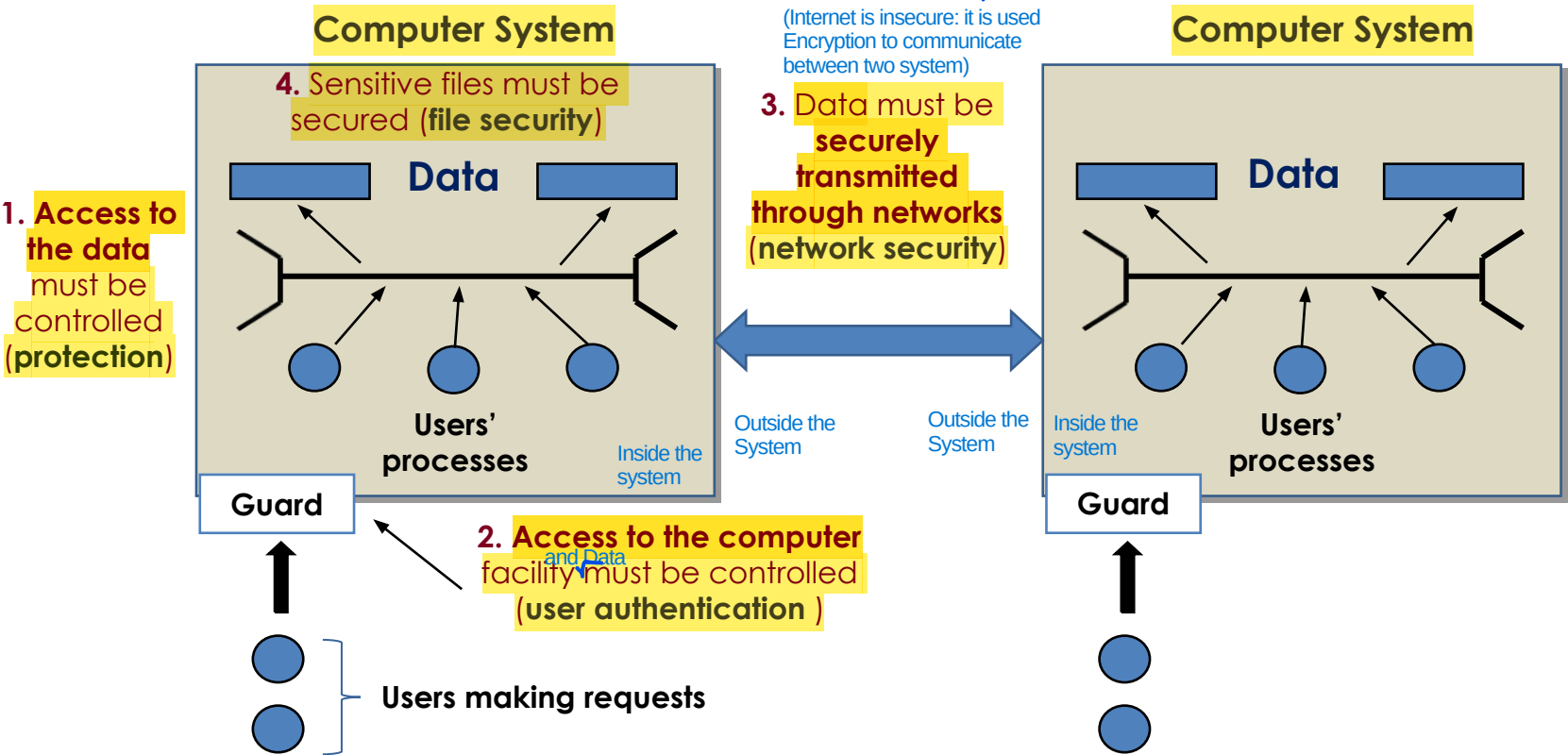
Once you have defined the Threats and their Consequences, you move from the "What can go wrong?" phase to the "What do we do about it?" phase. In a professional security framework, this follows a specific logical flow: Risk Assessment (Probability, Impact) -> Security Policy (Prevent, Detect, Recover) -> Security Implementation.

Scope of Computer Security

(Example of Attack:
Man-in-the-middle, somebody
intercepting communication,
modifying packets and impersonating
the destination of packets)



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



The table is not so perfect because some things are obsolete/missing: can be used as Guideline to spot easily what are the typical issues in different types of entities composing our system. So this table is good to be used as Guideline to analyse the system security in terms of CIA Triad or design properly a system). If a mechanism (part of system) can't properly react/resist to these kind of actions by the attacker (example: Data Integrity Issues), it means that you are using a System that is prone to this kind of actions

Scope of Computer Security

Digital Forensics: it is the practice of identifying, preserving, extracting, and documenting computer evidence so that it can be used in a court of law or an internal investigation.

Big issue of Data Conf and Integrity: how to know that the unauth read/modification/creation has been done? You need a proper infrastructure (track the data leaked/modified/created or possibly (report sec. incident: what data been leaked or potentially. You can't lie or be fined))

CIA Triad

Type of Entities/Resources considered in CyberSecurity	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	Author of the book thinks that rarely the integrity of the hardware can be affected
Software	Programs are deleted, denying access to users	It is Software Piracy An unauthorized copy of software is made	A working program is modified to cause it to fail or to cause it to do some unintended task
Data	(Example: Ramsonware) Files are deleted, denying access to users	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data (User Auth and Authorization (Access Control) is important)	User Auth and Control Access is important (if the file can be modified only be his author, we don't have unauthorized modifications) Existing files are modified or new files are fabricated Given that we aren't able to verify a property, we try to avoid the problem by means of a constraint in the definition of the problem itself (Instead of constantly checking if a file is "correct," you limit who can touch it so that it cannot be incorrect: this is shifting from Detection (checking for errors) to Prevention by Design (using constraints to make errors impossible).)
Communication Lines	(Internet is not designed for Availability) Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	example: same communication with server for paying will be duplicated to do the same other times Messages are read. Traffic patterns are observed reordered: if a protocol doesn't have a Sequence Number, an attacker can modify the order of the messages	Messages are modified, delayed, reordered, duplicated, False messages are fabricated All actions that an entity between source and destination can do with a Packet if the channel isn't secure (ex: HTTP)

Scope of Computer Security



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	
Software	Programs are deleted, denying access to users	An unauthorized copy of software is made	A working program is modified to cause it to fail or to cause it to do some unintended task
Data	Files are deleted, denying access to users	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data	Existing files are modified or new files are fabricated
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Messages are modified, delayed, reordered, duplicated. False messages are fabricated



Reads the content of the card (that isn't properly secured)

Example: the ATM skimmers



Integrity



A working program is modified to cause it to fail or to cause it to do some unintended task

Existing files are modified or new files are fabricated

Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Scope of Computer Security



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	
Software	Programs are deleted, denying access to users	Or encrypted!	
Data	Files are deleted, denying access to users		
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Sco

Hardware

Software

Data

Communication

MA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

grity

program is
use it to fail or
to do some
ed taske modified or
fabricatede modified,
eordered,
lse messages
icated

Your personal files are encrypted!



Private key will be destroyed on
10/20/2013
12:37 PM

Time left
72 : 34 : 50

Your important files **encryption** produced on this computer: photos, videos, documents, etc. [Here](#) is a complete list of encrypted files, and you can personally verify this.

Encryption was produced using a **unique** public key [RSA-2048](#) generated for this computer. To decrypt the files you need to obtain the **private key**.

The **single copy** of the private key, which will allow you to decrypt the files, located on a secret server on the Internet; the server will **destroy** the key after a time specified in this window. After that, **nobody and never will be able** to restore files...

To obtain the private key for this computer, which will automatically decrypt files, you need to pay **300 USD / 300 EUR** / similar amount in another currency.

Click «Next» to select the method of payment.

Any attempt to remove or damage this software will lead to the immediate destruction of the private key by server.

[Next >>](#)

Your personal files are encrypted!

Your important files **encryption** produced on this computer: photos, videos, documents, etc. [Here](#) is a complete list of encrypted files, and you can personally verify this.

Encryption was produced using a **unique** public key [RSA-2048](#) generated for this computer. To decrypt the files you need to obtain the **private key**.

The **single copy** of the private key, which will allow you to decrypt the files, located on a secret server on the Internet; the server will **destroy** the key after a time specified in this window. After that, **nobody and never will be able** to restore files...

crypt files, you

Based on Zero-Days (discovered but not reported to Microsoft, so stolen by other company)

Case Study: WannaCry

Private

immediate

Time left

72 : 34 : 50

Next >>

program is
use it to fail or
to do some
ed task

e modified or
fabricated

e modified,
eordered,
lse messages
icated

Sco

Hardware

Software

Data

Communication

Scope of Computer Security



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	
Software	Programs are deleted, denying access to users	An unauthorized copy of software is made	A working program is modified to cause it to fail or to cause it to do some unintended task
Data	Files are deleted, denying access to users	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data	Existing files are modified or new files are fabricated
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Passive and Active Attacks

Kind of mitigation is different from
Passive (cannot perform Reactive Security) to Active (Reactive Security)



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Passive attacks** attempt to **learn** or make use of information from the system **but do not affect system resources** (Example: sniff packets during communication)



Eavesdropping is the unauthorized interception of private communication. In a digital network, this usually means capturing "packets" of data as they travel from Point A to Point B. (to avoid that they get sensitive information, use encryption)

example: eavesdropping/monitoring of transmissions

One is a Passive Attack (illegal/unauthorized), while the other is a Security Control (legal/authorized).

- **difficult to detect** because you have small or no evidence that they are doing Passive Attacks (because there aren't any type of modifications to system resources)
- emphasis is on **prevention rather than detection** There is no easy mitigation of it
- **two** main types (**message contents, traffic analysis**)

Passive and Active Attacks



ALMA MATER STUDIORUM
BOLOGNA

The transmission is intercepted

- **Passive attacks** attempt to intercept data without affecting the system **but do not affect system resources**
 - **example:** eavesdropping/monitoring of transmissions
 - **difficult to detect**
 - emphasis is on **prevention** rather than detection
 - **two** main types (**message contents**, **traffic analysis**)

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Passive attacks** attempt to **learn** or make use of information from the system **but do not affect system resources**
 - **example**: eavesdropping/monitoring of transmissions
 - **difficult to detect**
 - emphasis is on **prevention** rather than detection
 - **two** main types (**message contents**, **traffic analysis**)

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Content can be in clear or encrypted (it depends on the channel encryption)

- **Passive attacks** attempt to intercept data from a system **but do not affect** system
 - **example:** eavesdropping
 - **difficult to detect**
 - emphasis is on **prevention** rather than detection
 - **two** main types (**message contents**, traffic **analysis**)

This happens when the message
is transmitted “in clear”
(not encrypted) message text
encrypted: cypher text



Even when the messages are encrypted
it is possible to perform some analysis

For example: content size, frequency...

- **difficult to detect**
- emphasis is on **prevention** rather than detection
- **two** main types (**message contents**, **traffic analysis**)

It is important to be able to understand the different categories, so when you try to analyse the security of the system (example: system that you are designing/developing), it will be easier for you to try to follow these approach (an example is the table seen) and to ask to yourself if the system is prone to these type of attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Passive and Active Attacks

- **Active attacks** involve **modification** of the data stream (or the attacked system)

If there is modification/interaction with the system, it is an Attack System
If there isn't, it is a Passive Attack

- the **goal** is to **detect** them and to **recover**

Intrusion Detection System (type of software that its goal is detecting something abnormal is happening: that can be legitimated or start recover). In Intrusion Prevention System, respect to IDS, it is also reactive: trying to do something to stop the system before it is compromised.

4 categories

○ four main types:

of active attacks

- **masquerade**
- **replay**
- **modification of messages**
- **denial of service**

Typical these attacks occurs on the Internet because it is easier when there is a network than inside a system (more secure than internet and much harder)

Typical Attack:
- Passive to gather information without being spotted
- Active to perform it using info gathered before

Passive



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

One **entity** pretends to be a
different entity

Example: a **user** or a **device**

- **Active attacks**

attacked

or the

- the **goal** is to **steal** them and to **recover**
- four main types:

- **masquerade**
- **replay**
- **modification of messages**
- **denial of service**

Passive and Active

- **Active attacks** involve an attacker (or attackers) interacting with the attacked system)
 - the **goal** is to compromise the system
 - four main types

Direct Replay: no modifications

Attacker can modify the message if it isn't properly encrypted

Passive capture of a data unit and its subsequent **retransmission** to produce an unauthorized effect:

Man-In-The-Middle (MITM) attack

Example: "Open sesame"

Couple of words without meaning but i understand the semantic (opens the door)

In some type of attacks, you can use masquerade+replay (used to bypass both Authentication and Access Control.)

- **masquerade**
- **replay**
- **modification of messages**
- **denial of service**

"it is the subsequent retransmission" to define that it is an Active Attack

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Active attacks**

attacked

- the s

- four main ty

- masquer

- replay

- **modification of messages**

- denial of service

I think that it is obvious

Example: to change the IBAN
code in a bank transfer

Modify a part of the communication

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Active attacks**

attacked system

- the **goal**
- four main

- masquerade
- replay
- modification of messages
- **denial of service**

An **interruption** in an authorized user's access to a computer network, typically one caused with malicious intent

Example: the *Mirai* botnet

Even if they are important, It is very difficult/impossible to be able to design a product that satisfies all design principles that are listed here. Not all the design principles have same importance: some of them are more important than others and it depends on your setup (a Bank has a Threat Model differente from the others, for example)

Security Design Principles

IMPORTANT: A good blueprint/guideline to how to design a proper cybersecurity aware system or evaluate a system



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

1

Another formulation of KISS

● **Economy of mechanism**: the design of security measures should be **as simple as possible** (i.e. **simpler** to implement and to verify, **fewer vulnerabilities**)

2

● **Fail-safe default**: access decisions should be based on **permissions rather than exclusion** (i.e., the **default** is lack of access)

It is preferred to automatically restrict the permissions and only by human intervention (admin), we will decide case by case who is authorized to enter in the system

3

Implementing Complete mediation is costly (in terms of design, interaction between the different parts, etc..)

● **Complete mediation**: every access should be checked against the **Access Control system** (see Chapter 4)

Authorization: what resources, the user authenticated, can access and with which permissions.

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- 4 • **Open design**: the design should be **open rather than secret** (e.g., *encryption algorithms*) (Shannon Reformulation)

- 5 **Separation of privileges**: **multiple privileges** should be required to achieve access to a restricted resource (or to complete some tasks)
not only for users but even for software
- 6 **Least privilege**: every user (or process) should operate **using the ~~least~~ ^{minimum} set of privileges** necessary to perform a task (e.g., the sysadmin must **not** surf the Web using the administrator user)
- It is the opposite of usability (when i use the PC i want all the permissions to avoid slowing my operations)
- otherwise, a single compromise, in a single part of the system, is able to get a lot of credentials, to compromise other parts of the system, etc..

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



(example: reduce the amount of accounts with same password because with one data breach, you are compromised on all accounts). When different users or programs share a mechanism (like a password, a database, or a piece of memory), that mechanism becomes a Single Point of Failure.

• **Least common mechanism**: a design should minimize the **functions**

shared by different users/entities (e.g., *sharing state among different*

software programs)

If you create different environments that are divided by them, you are implementing Least Common Mechanism. If you have something that is overlapping, it is easier to get a compromise that is not confined only to a single software (because there is interaction between different part of the software) (LCM not implemented).



• **Psychological acceptability**: the security mechanisms should not

eccessivamente (overly)

interfere ~~unduly~~ with the work of users (*i.e. user's acceptance of*

security mechanisms)

When we try to push for an increase of Security level, everytime you should consider carefully what is the psychological reaction of the users: if the psychological reaction of the users is something that is against the acceptability of enforcing this specific mechanism, we are doing something wrong:

1) Why are they reacting like that?

2) Investigating if there is a better way for doing things (most of the times, there are but costly and not so easy for admin, so we prefer to push the problem to the user instead of solve the problem as system administrator)



Security Design Principles

When you design a system, you shouldn't aim for "Maximum Isolation." You should aim for Optimal Isolation. You identify the most critical resources and isolate those, while leaving non-critical paths more open to keep the system fast (too much Isolation lowers system performance).

Isolation:

Not all kinds of isolation are the same: there are different type of isolation (for example, is better the physical isolation than logical, but the physical one is costier than logical one) and different type of software/hardware isolation

- **public access** should be isolated from critical resources (*i.e., no*

connection between public and critical information)

Example: (Air Gapping) Se un componente è esposto al pubblico (come un server web), non deve avere una "linea diretta" verso le risorse critiche (come il database dei pagamenti o i file di sistema).

- **users files** should be isolated from one another (except when

desired) (example: same computer, different users registered in the PC, so we have logical isolation of files: users are separated)

as much as possible, otherwise it will possible for the attacker to compromise the security mechanism and after that to escalate on the whole system (get super privilege on the system)

- the **security mechanism** should be isolated (*i.e., preventing*

access to those mechanisms)

With Modularity and Isolation, we enter the debate about The Monolithic Kernel vs. The Microkernel:

In a monolithic system (like Linux, Windows, or macOS), almost all core services (drivers, file systems, and the Security Module) run in the same "privileged" memory space (Kernel Space): we have more performance but less Isolation and Modularity.

A Microkernel (like QNX or L4) takes the opposite approach. It only keeps the absolute "bare essentials" in the kernel. Everything else (drivers, file systems, security) runs as a separate, isolated Module.

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Idea behind: redesign the system in a way that every single modification/interaction to the system is mediated by another piece of software that is in charge of doing that (solves problems about concurrency and boost accountability (responsibility on actions) in the system)

10 **Encapsulation**: similar to **object-oriented programming concepts** (i.e.,

hide internal structures)

You should never be able to modify directly something from a part of the system (example: Data Structure, that can be also a File System that is shared inside a network, and there are a different nodes that can, at the same time, concurrently, modify its shared resource, you have a problem: because there is no entity inside the system that is in charge of the management of this shared resource)

Idea of Isolation and Separation, but in this case specifically applied to the part about security functions. Idea: if i create a system in which the security functions are meld together with the other functions of the system, i have a problem because they are not properly separated (if there is modularity, it is easier to protect the security stuff of the system)

11 **Modularity**: development of security functions as **separate, protected**

modules and use of a **modular architecture** (*for the mechanism*

design and implementation)

It is not easy to do it (implementation is hard to do). For example, the OS gives us the security module that is incorporated inside the OS: this goes against Modularity, but this is the best way of doing it because although i need to extrapolate the security module from the OS and put it in a separate part of the kernel. If you prioritize Modularity, the system becomes slow and users will hate it (Psychological Acceptability). If you prioritize Integration, the system is fast but one "Kernel Exploit" (like the SMB bug in WannaCry) can bypass every security check at once.

It is a good idea to centralize the Security Module instead of Replicate them in each File System

The difference between bad and good security is on the properly understanding of the Thread Model and not applying Security design principle that are useless and costly in situation in which they aren't able to mitigate the problem itself. If you apply a high-cost security principle to a low-risk asset, you aren't being "more secure", you are being inefficient.



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Security Design Principles

Layering can be really good if it is able to enhance your security when considering the proper Threat Model (if you aren't, layering is only a problem of usability). Example: (online banking) if you consider in the Thread Model the compromise of the browser/user device, all the layering is totally useless because the browser is the single piece of software that is in charge of getting all of your credentials and to transfer all these credentials to the backend

Idea behind this approach: risk reduction by heterogeneity. Instead of having a single line of defense, is better to have multiple line of defenses

also called

Layering (defense in depth): use of **multiple, overlapping** protection

approaches (e.g., *multiple firewalls based on different technologies*

and approaches) Each layer is implemented in a different way (different technologies, manufactures, etc.). Example: different type of Firewall or different type of Authentications

Least astonishment: a program or interface should always respond in

a way that ^{causes the user as little surprise as possible} is ~~least likely to astonish a user~~ (e.g., *an error window that*

belong to what running program?)

If the user can be misled on a window request, the security consequences can be terrible. For example, a window that asks to confirm the password, how to know if it is a legitimate one or another application that is trying to impersonate

12

Related to
Managment
and Technical

13

Related to Psychology

Security Mechanism



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- It is (or it should be) **designed to**:
 - **prevent** attackers from violating security policy
 - **detect** attackers' violation of security policy
 - **response** to **mitigate** attack
 - **recover**, continue to function **correctly** even if **attack succeeds**
- No single mechanism is able to support all services:
 - **Example**: *authentication, authorization, availability, confidentiality, integrity, non-repudiation*

Attack Surface



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- The **reachable** and **exploitable** vulnerabilities in a system:
 - **services** listening on the network
 - **services** that are **not protected by a firewall**
 - **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
 - an **employee** (or a **subcontractor**) with **access to sensitive information**

Attack Surface



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- The **reachable** and **exploitable vulnerabilities** in a system:

- **services listening on the network**

“Open ports”: running processes using network sockets

- an employee (or a subcontractor) with **access to sensitive information**



A “**firewall**” is a software or hardware tool used to **restrict the network access to a system**

abilities in a system:

- **services** **listening on the network**
- **services** that are **not protected by a firewall**
- **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
- an **employee** (or a **subcontractor**) with **access to sensitive information**



Its goal is to **permit authorized access** and to **deny unauthorized (i.e., malicious) attempts**

abilities in a system:

- **services** **listening on network**
- **services** that are **not protected by a firewall**
- **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
- an **employee** (or a **subcontractor**) with **access to sensitive information**

Attack Surface



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- The **reachable** and **exploitable** vulnerabilities in a system:
 - **services** listening on the network
 - **services** that are **not protected by a firewall**
 - **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
 - an **employee** (or a **subcontractor**) with **access to sensitive information**

Attack Surface



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

... but also **Application
Programming Interfaces (APIs),
SQL queries, web forms ...**

abilities in a system:

- **services** that are **protected by a firewall**
- **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
- an **employee** (or a **subcontractor**) with **access to sensitive information**



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Network Scanning



NMAP

Exposed attack surface

What is it?

Check it out!

T1

Attack Surface: **categories**



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Three main **categories**
 - **network** attack surface (i.e. **network vulnerability**)
 - **software** attack surface (i.e. **software vulnerability**)
 - **human** attack surface (i.e. **social engineering**)
- Attack surface **analysis**
 - **assessing the scale and severity of threats** (i.e. to decide **how to allocate** the available resources)... it is **not easy**...

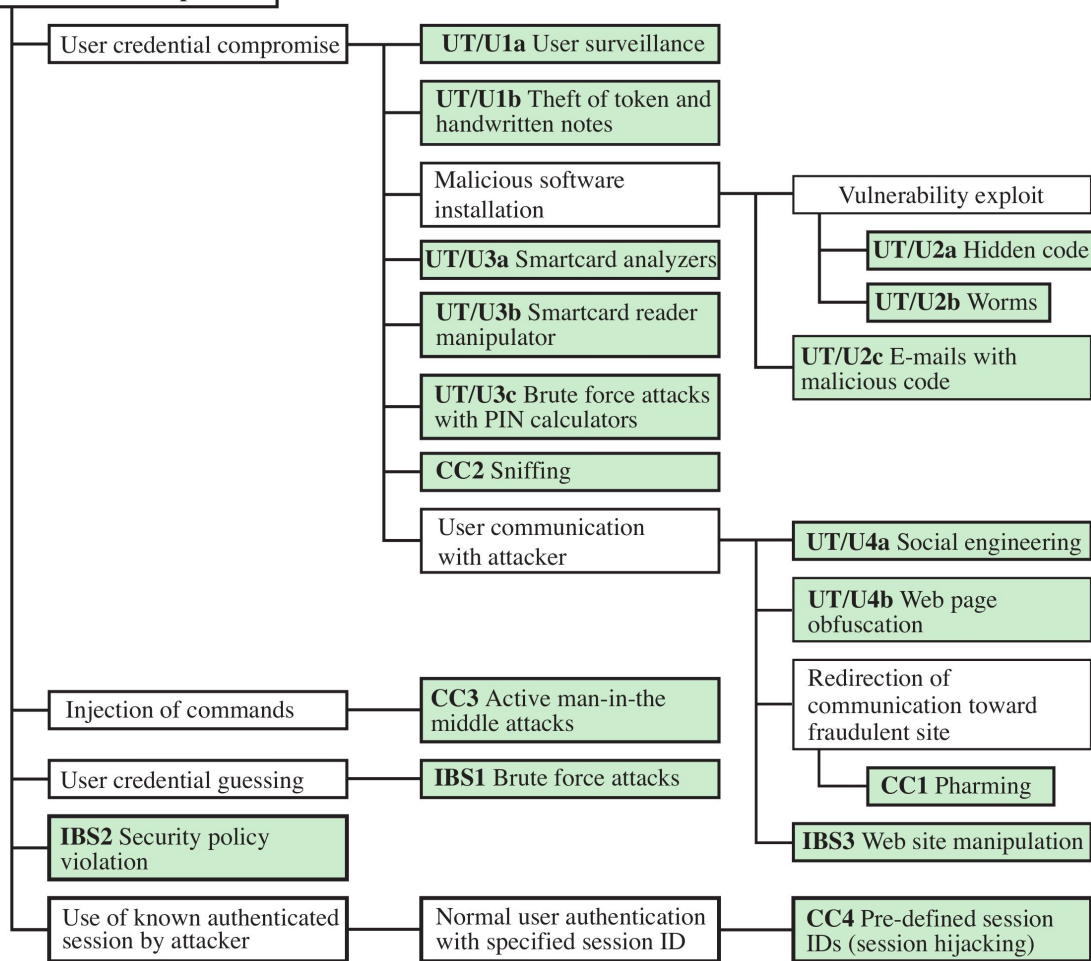
Attack Trees



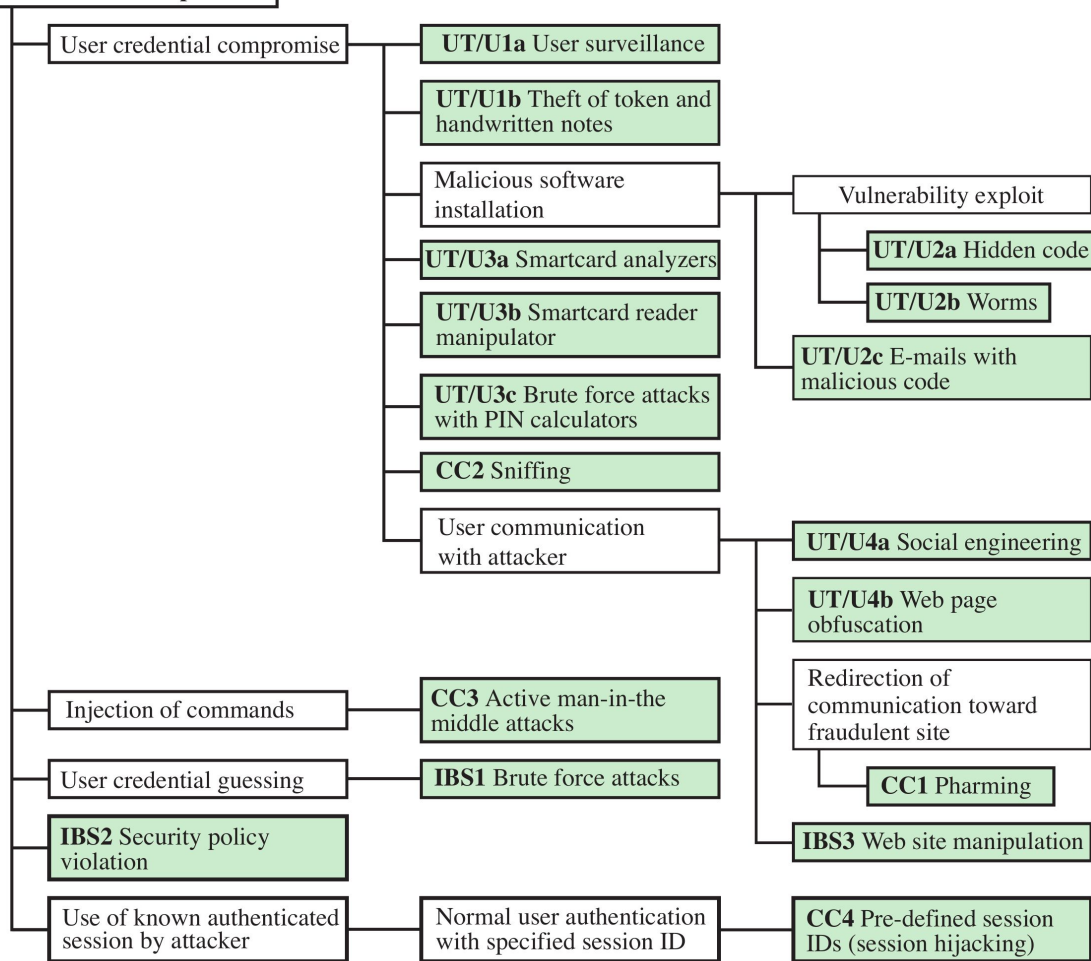
ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Attack trees** are often used to perform **attack surface analysis**
- An **attack tree** is a **branching, hierarchical** data structure that **represents a set of potential vulnerabilities**
- **Objective:** to effectively exploit the info available on **attack patterns**
(i.e. the methods used to find errors or problems in the systems)
- **Attack trees** can be used by the **security analysts** **to guide design and strengthen countermeasures**

Bank Account Compromise



Bank Account Compromise

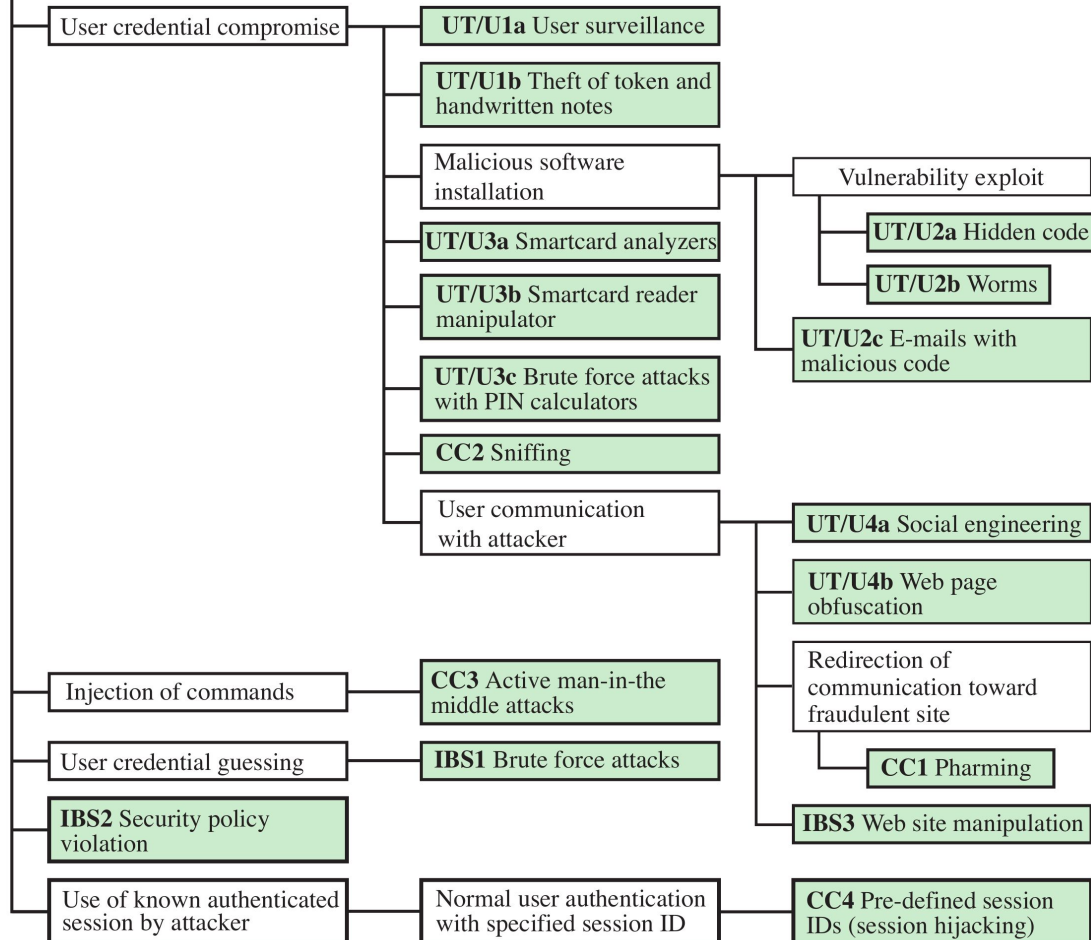


The goal is to compromise an online bank account



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Bank Account Compromise



The goal is to compromise
an online bank account

This can be done in many
different ways



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Bank Account Compromise

User credential compromise

UT/U1a User surveillance

UT/U1b Theft of token and handwritten notes

Malicious software installation

UT/U3a Smartcard analyzers

UT/U3b Smartcard reader manipulator

UT/U3c Brute force attacks with PIN calculators

UT/U3d Sniffing

UT/U3e Communication hijacker

Vulnerability exploit

UT/U2a Hidden code

UT/U2b Worms

UT/U2c E-mails with malicious code

UT/U4a Social engineering

For example:
**compromising the
credentials**

Injection of

User creden

IBS2 Security violation

Use of known authenticated session by attacker

with specified session ID

with specified session IDs (session hijacking)

The goal is to compromise
an online bank account

This can be done in many
different ways



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Bank Account Compromise

User credential compromise

UT/U1a User surveillance

UT/U1b Theft of token and handwritten notes

or **guessing** them
(i.e., weak passwords)

Injection of command

CC3 Active man-in-the middle attacks

User credential guessing

IBS1 Brute force attacks

IBS2 Security policy violation

Use of known authenticated session by attacker

Normal user authentication with specified session ID

UT/U4a Social engineering

UT/U4b Web page obfuscation

Redirection of communication toward fraudulent site

CC1 Pharming

IBS3 Web site manipulation

CC4 Pre-defined session IDs (session hijacking)

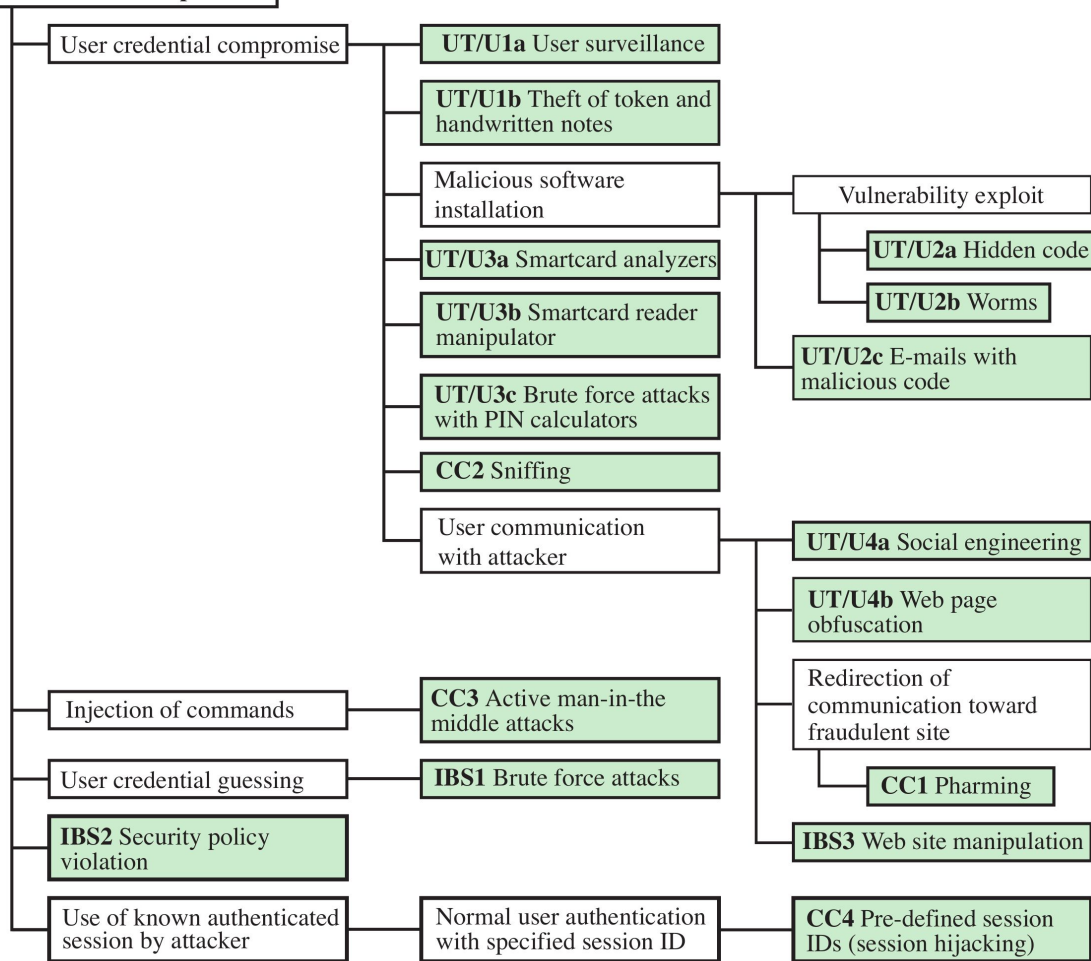
The goal is to compromise an online bank account

This can be done in many different ways



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Bank Account Compromise





ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

CyberSecurity

Gabriele D'Angelo

<g.dangelo@unibo.it>

<https://www.unibo.it/sitoweb/g.dangelo/en>

www.unibo.it

Attributions and Notes



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Most of the slides are from: “**Computer Security: Principles and Practice**”, 4th global edition, W. Stallings and Lawrie Brown
- Some others are from: Dr. **Mehmet H. Gunes** (Department of Computer Science & Engineering - University of Nevada, Reno)
- Some others are from: **Mario Cagalj**, Ph.D. (Faculty of Electrical Engineering, Mechanical Engineering and Naval Architecture (FESB), University of Split)
- Some others are from: Prof. **Hossein Saiedian**, University of Kansas
- The “risk matrix” is from this [blog](#)
- I wish to **thank all of them**, **any errors that remain are my sole responsibility**